School of Information and Computer Technology
Sirindhorn International Institute of Technology, Thammasat University
CSS326 Database Programming Laboratory

Laboratory Assignment #10: Hardening: Performance & Security

Objectives:

- To speed up queries with indexes and verify the gain with EXPLAIN and EXPLAIN ANALYZE.
- To defend against SQL injection with parameterised queries.
- To apply least privilege with a dedicated database user and keep secrets out of code.

Scenario: harden your bookstore application for real-world use. Make its queries fast with indexes, and make it safe against injection and over-privileged access. You will measure query plans with EXPLAIN and EXPLAIN ANALYZE, add indexes, secure your queries and connection, and protect your secrets.

```
books(     id, title, author, price, stock )
customers( id, name, email )
orders(    id, customer_id, book_id, quantity )

-- database: bookstore_lab10 (50,008 books, 5,005 customers, 100,008 orders)
```

First load the bookstore database: in MySQL Workbench, as root, run the three files in the sql folder of Lab10_Assignment_Starter.zip in order (01_bookstore_schema.sql, 02_bookstore_sample_data.sql, 03_bookstore_bulk_data.sql). They create a separate bookstore_lab10 database, so your earlier bookstore data is left untouched. Write your SQL in sql/assignment10_starter.sql and make the code changes in the provided bookstore web app. Submit your SQL file, the changed code files, and screenshots of the EXPLAIN and EXPLAIN ANALYZE output before and after indexing. This assignment is marked out of 12.

```
npm install      # once: downloads express and mysql2
npm run dev      # starts the server on http://localhost:3000 (Ctrl + C stops it)
```

For now, put your root password in `db.js` (Q6 and Q7 change that). Open **http://localhost:3000**: the bookstore web app shows a **Connection** panel (which user the app logs in as, and its privileges: Q6, Q7), a **Query plan** panel (EXPLAIN of the author search and the indexes on books: Q1, Q2), **Books by author** with the server time of every request and attack buttons (Q1, Q2, Q5), **A customer's orders** with an EXPLAIN of the join (Q3), and a **Responses** log that turns red when something is unsafe. Screenshots of these panels are acceptable evidence alongside your Workbench screenshots.

1. Measure first. Choose a query that filters on a non-key column, for example books by the author 'Ben Forta'. Run EXPLAIN and EXPLAIN ANALYZE on it and record the type, key, rows and actual time. Include a screenshot. **(1.5 points)**
2. Add an index. Run CREATE INDEX on that column, then run the same EXPLAIN and EXPLAIN ANALYZE again. Report how type, rows and actual time changed, and include the after screenshot. **(1.5 points)**

3. Joins and foreign keys. Run SHOW INDEX FROM orders, then use EXPLAIN on a query that joins orders to customers for one customer (for example, customer id 42). Which index does the join use on orders, and why does that index exist even though you never created it? **(1.5 points)**
4. The cost of indexes. In two or three sentences, explain one downside of adding an index, and how you would decide which columns are worth indexing. **(1 point)**
5. Injection and the fix. The author search in controllers/bookController.js builds SQL by concatenating a value. Show the original code, explain how the input ' OR '1'='1 changes what the query does, then rewrite it with a ? placeholder and explain why the rewrite is safe. **(2 points)**
6. Least privilege. Create a dedicated MySQL user named bookstore_app and GRANT it only SELECT, INSERT, UPDATE and DELETE on the bookstore_lab10 schema. Show the output of SHOW GRANTS, and show that the user cannot DROP a table. Point the application's connection at this user instead of root, and confirm that the application still works. **(2 points)**
7. Protect secrets. Move the database settings out of your code into a .env file read with process.env, add .env to .gitignore, confirm that the application still connects, and explain why .env should not be committed to Git. **(1.5 points)**
8. Short answer. In two or three sentences, explain why the application should not connect as root, and name one further security measure beyond those above. **(1 point)**